

Vulnerabilities Report

1. Cross-Site Scripting (XSS)

Description: XSSStrike ■[97mv3.1.5

Tags:

<https://owasp.org/www-community/attacks/xss/>

Risk: High

URL: http://192.168.56.101/dvwa/vulnerabilities/xss_r/

Method: GET

2. Session Management Response Identified

Description: The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Tags:

Risk: Informational

URL: http://192.168.56.101/dvwa/vulnerabilities/xss_r/

Method: GET

3. Cookie No HttpOnly Flag

Description: A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.

Tags:

CWE-1004

OWASP_2021_A05

WSTG-v42-SESS-02

SYSTEMIC

OWASP_2017_A06

Risk: Low

URL: http://192.168.56.101/dvwa/vulnerabilities/xss_r/

Method: GET

4. Cookie without SameSite Attribute

Description: A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.

Tags:

OWASP_2021_A01

WSTG-v42-SESS-02

SYSTEMIC

CWE-1275

OWASP_2017_A05

Risk: Low

URL: http://192.168.56.101/dvwa/vulnerabilities/xss_r/

Method: GET

5. Server Leaks Version Information via "Server" HTTP Response Header Field

Description: The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.

Tags:

OWASP_2021_A05

SYSTEMIC

OWASP_2017_A06

WSTG-v42-INFO-02

CWE-497

Risk: Low

URL: http://192.168.56.101/dvwa/vulnerabilities/xss_r/

Method: GET

6. User Agent Fuzzer

Description: Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

Tags:

SYSTEMIC

Risk: Informational

URL: http://192.168.56.101/dvwa/vulnerabilities/xss_r/

Method: GET